

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN



BÁO CÁO TIỂU LUẬN CUỐI KỲ

HỌC PHẦN: BẢO MẬT IOT

GIẢ MẠO THIẾT BỊ TRONG HỆ THỐNG IOT

GIẢNG VIÊN GIẢNG DẠY: HỒ NHỰT MINH

HỌ VÀ TÊN HỌC VIÊN: LÊ CHÍ TÂM

MÃ HỌC VIÊN: 231A010500

LỚP: 253INT441001

TP. HỒ CHÍ MINH - 2026

THÔNG TIN VÀ CAM KẾT NỘP BÀI

Tên đề tài	Giả mạo thiết bị trong hệ thống IoT
Mã đề tài	28
Sinh viên/Nhóm	Lê Chí Tâm
Repo GitHub	https://github.com/lechitam1602-dot/De-tai-28-Gia-mao-thiet-bi-trong-he-thong-IoT.git
Bản báo cáo	231A010500_LeChiTam_28_BaoCao.docx 231A010500_LeChiTam_28_BaoCao.pdf
Bản trình chiếu	231A010500_LeChiTam_28_BaoCao.pptx
Sản phẩm chính	Code/config/sơ đồ/quy trình
Ngày nộp	25/07/2026

Cam kết an toàn và học thuật

Tôi/chúng tôi cam kết toàn bộ thử nghiệm được thực hiện trong môi trường cục bộ, thiết bị thuộc quyền sở hữu hoặc dữ liệu giả lập/được phép; không quét, khai thác hay thu thập dữ liệu từ hệ thống thật. Báo cáo, mã nguồn và minh chứng là kết quả làm việc của cá nhân/nhóm; mọi nội dung kế thừa đều được trích dẫn rõ ràng. Repo không chứa secret, token, mật khẩu hoặc dữ liệu cá nhân thật.

- Họ tên người cam kết: Lê Chí Tâm
- Ngày cam kết: 25/07/2026
- Chữ ký: Lê Chí Tâm

MỤC LỤC

DANH MỤC TỪ VIẾT TẮT	i
PHIẾU XÁC ĐỊNH YÊU CẦU RIÊNG CỦA ĐỀ TÀI.....	ii
CHƯƠNG 1: MỞ ĐẦU.....	1
1.1. Bối cảnh và lý do chọn đề tài	1
1.1.1 Bối cảnh của Internet of Things (IoT).....	1
1.1.2 Vấn đề bảo mật cần giải quyết	1
1.1.3 Đối tượng chịu ảnh hưởng.....	1
1.1.4 Lý do đề tài có ý nghĩa	1
1.2. Phát biểu vấn đề.....	2
1.3. Mục tiêu	2
1.4. Đối tượng và phạm vi	3
1.4.1. Đối tượng nghiên cứu.....	3
1.4.2. Phạm vi nghiên cứu.....	3
1.5. Sản phẩm dự kiến và đóng góp.....	3
CHƯƠNG 2: CƠ SỞ LÝ THUYẾT VÀ NGUỒN LIÊN QUAN	4
2.1. Kiến trúc, giao thức hoặc công nghệ nền.....	4
2.1.1. Kiến trúc hệ thống Internet of Things (IoT).....	4
2.1.2. Giao thức HTTP và REST API.....	4
2.1.3. Flask Framework.....	4
2.1.4. Quản lý định danh thiết bị (Device Identity).....	5
2.1.5. Mbed TLS	5
2.2. Khái niệm bảo mật liên quan.....	5
2.2.1. Tài sản cần bảo vệ	5
2.2.2. Mối đe dọa.....	5
2.2.3. Lỗ hổng bảo mật.....	6
2.2.4. Rủi ro bảo mật.....	6
2.2.5. Biện pháp kiểm soát	6
2.2.6. Cơ chế mật mã và mô hình đe dọa	6
2.3 Chuẩn, tài liệu và công cụ GitHub	7
2.4. Công trình/giải pháp liên quan.....	7
CHƯƠNG 3: PHƯƠNG PHÁP VÀ THIẾT KẾ	9
3.1. Phương pháp thực hiện	9
3.2. Kiến trúc, mô hình và luồng dữ liệu.....	9
3.3. Môi trường, công cụ và dữ liệu.....	10
3.4. Quy trình thực hiện	11
3.5. Giới hạn an toàn và đạo đức	11
CHƯƠNG 4: TRIỂN KHAI VÀ SẢN PHẨM.....	13
4.1. Chuẩn bị môi trường	13
4.2. Thành phần sản phẩm.....	13
4.3. Kịch bản thử nghiệm/đánh giá	13
4.4. Hướng dẫn chạy hoặc sử dụng sản phẩm	13

CHƯƠNG 5: KẾT QUẢ VÀ THẢO LUẬN	14
5.1. Kết quả chính	14
5.2. Bảng tổng hợp kết quả.....	15
5.3. Đối chiếu mục tiêu.....	16
5.4. Hạn chế	17
CHƯƠNG 6: ĐÁNH GIÁ BẢO MẬT	18
6.1. Tài sản và dữ liệu cần bảo vệ	18
6.2. Môi đe dọa và lỗ hổng.....	18
6.3. Ma trận rủi ro	19
6.4. Biện pháp giảm thiểu và ưu tiên.....	20
6.5. Đánh giá an toàn sau xử lý	21
CHƯƠNG 7. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN.....	22
7.1. Kết luận.....	22
7.2. Hướng phát triển.....	22
TÀI LIỆU THAM KHẢO	23

DANH MỤC TỪ VIẾT TẮT

STT	Từ viết tắt	Tên đầy đủ (Tiếng Anh)	Giải thích / Nghĩa tiếng Việt
1	API	Application Programming Interface	Giao diện lập trình ứng dụng
2	DDoS	Distributed Denial of Service	Tấn công từ chối dịch vụ phân tán
3	HMAC	Hash-based Message Authentication Code	Mã xác thực thông điệp dựa trên hàm băm
4	HTTP	Hypertext Transfer Protocol	Giao thức truyền tải siêu văn bản
5	HTTPS	Hypertext Transfer Protocol Secure	Giao thức truyền tải siêu văn bản an toàn
6	ID	Identifier / Identification	Mã định danh / Nhận dạng
7	IIoT	Industrial Internet of Things	Internet kết nối mọi thứ trong công nghiệp
8	IoT	Internet of Things	Internet kết nối mọi thứ / Mạng lưới thiết bị kết nối
9	ISVS	IoT Security Verification Standard	Tiêu chuẩn xác minh bảo mật IoT (thuộc OWASP)
10	IT	Information Technology	Công nghệ thông tin
11	JSON	JavaScript Object Notation	Định dạng dữ liệu đối tượng JavaScript
12	JWT	JSON Web Token	Mã định danh / xác thực dạng chuỗi JSON
13	MitM	Man-in-the-Middle	Tấn công người đứng giữa (nghe lén / can thiệp dữ liệu)
14	MQTT	Message Queuing Telemetry Transport	Giao thức truyền thông điệp nhẹ cho thiết bị IoT

STT	Từ viết tắt	Tên đầy đủ (Tiếng Anh)	Giải thích / Nghĩa tiếng Việt
15	mTLS	Mutual Transport Layer Security	Bảo mật lớp truyền tải xác thực hai chiều
16	OWASP	Open Web Application Security Project	Dự án bảo mật ứng dụng web mở
17	REST	Representational State Transfer	Kiểu kiến trúc thiết kế dịch vụ web (Web Service)
18	SSL	Secure Sockets Layer	Lớp ổ cắm an toàn (giao thức bảo mật kết nối)
19	TLS	Transport Layer Security	Bảo mật lớp truyền tải (giao thức mã hóa dữ liệu)

PHIẾU XÁC ĐỊNH YÊU CẦU RIÊNG CỦA ĐỀ TÀI

Mã và tên đề tài	Đề tài 28 – Giả mạo thiết bị trong hệ thống IoT
Hướng đề tài	D
Vấn đề bảo mật cốt lõi	Kẻ tấn công lợi dụng việc thiếu xác thực danh tính hoặc sử dụng token/chứng chỉ giả để giả mạo thiết bị IoT hợp lệ gửi dữ liệu sai lệch hoặc nhận lệnh trái phép từ Server. Điều này đe dọa nghiêm trọng đến tính toàn vẹn của dữ liệu và sự an toàn trong vận hành hệ thống.
Ba mục tiêu bắt buộc	1. Phân tích nguy cơ: Đánh giá các kịch bản thiết bị giả gửi dữ liệu hoặc nhận lệnh điều khiển. 2. Triển khai phòng thủ: Xây dựng cơ chế kiểm tra token/chứng chỉ giả lập trên Server để phát hiện và ngăn chặn truy cập trái phép. 3. Quản lý định danh: Đề xuất quy trình quản lý, cấp phát và thu hồi định danh thiết bị IoT an toàn.
Sản phẩm/đầu ra bắt buộc	Code API kiểm tra thiết bị. File devices.json mẫu. Log request hợp lệ/giả mạo. Bảng quy trình cấp/thu hồi định danh thiết bị.
Nguồn GitHub/tool chính	https://github.com/lechitam1602-dot/De-tai-28-Gia-mao-thiet-bi-trong-he-thong-IoT.git
Minh chứng sẽ thu thập	Screenshot kết quả chạy Flask API tiếp nhận và xác thực request. File log minh chứng request hợp lệ được tiếp nhận và request giả mạo bị từ chối.
Phạm vi an toàn	Môi trường thử nghiệm cục bộ (Local / Flask Server giả lập) sử dụng dữ liệu giả lập, không can thiệp vào các hệ thống IoT thật.

CHƯƠNG 1: MỞ ĐẦU

1.1. Bối cảnh và lý do chọn đề tài

1.1.1 Bối cảnh của Internet of Things (IoT)

Internet of Things (IoT) đang phát triển với tốc độ đáng kinh ngạc, trở thành một phần không thể thiếu trong đời sống và sản xuất toàn cầu. Từ 13,1 tỷ thiết bị trực tuyến vào cuối năm 2022, con số này dự kiến sẽ vượt quá 25 tỷ thiết bị vào năm 2030. Công nghệ IoT đã được ứng dụng sâu rộng trong nhiều lĩnh vực then chốt như:

- Đời sống: Nhà thông minh, thiết bị đeo theo dõi sức khỏe và các thiết bị gia dụng kết nối.
- Công nghiệp (IIoT): Hệ thống điều khiển sản xuất, lưới điện thông minh, logistics và nông nghiệp công nghệ cao.
- Hạ tầng: Thành phố thông minh và các hệ thống giao thông vận tải hiện đại.

Sự hội tụ giữa công nghệ thông tin (IT) và công nghệ vận hành (OT) giúp IoT có khả năng tương tác trực tiếp với thế giới vật lý, mang lại hiệu quả vượt trội trong quản lý và điều hành.

1.1.2 Vấn đề bảo mật cần giải quyết

Dù mang lại lợi ích to lớn, sự phát triển nhanh chóng của IoT lại đi kèm với những nguy cơ an ninh mạng nghiêm trọng. Những vấn đề chính cần giải quyết bao gồm:

- Lỗ hổng phổ biến: Nhiều thiết bị tồn tại các điểm yếu như mật khẩu mặc định dễ đoán, giao thức truyền thông không mã hóa, và thiếu cơ chế cập nhật phần mềm an toàn.
- Mối đe dọa tinh vi: Hệ thống IoT là mục tiêu của các cuộc tấn công nguy hiểm như từ chối dịch vụ (DDoS), giả mạo (Spoofing), nghe lén dữ liệu (MitM) và mã độc tống tiền (Ransomware).

Trong số các mối đe dọa đối với hệ thống IoT, giả mạo thiết bị (Device Spoofing) là một trong những hình thức tấn công phổ biến. Kẻ tấn công có thể sử dụng Device ID hoặc Token bị đánh cắp để giả danh thiết bị hợp lệ nhằm gửi dữ liệu sai lệch hoặc nhận lệnh điều khiển từ máy chủ. Nếu máy chủ không có cơ chế xác thực thiết bị, các dữ liệu giả sẽ được chấp nhận, ảnh hưởng trực tiếp đến tính toàn vẹn và độ tin cậy của hệ thống.

1.1.3 Đối tượng chịu ảnh hưởng

Các lỗ hổng bảo mật trong IoT có thể gây ra tác động dây chuyền đến nhiều đối tượng khác nhau:

- Người dùng cá nhân: Bị xâm phạm quyền riêng tư qua các thiết bị như camera do thám, hoặc chịu thiệt hại tài chính từ các thiết bị thanh toán thông minh bị chiếm quyền điều khiển.
- Doanh nghiệp và tổ chức: Các vụ tấn công vào hạ tầng công nghệ cao có thể làm đình trệ sản xuất, gây thiệt hại tài chính hàng trăm triệu USD và làm mất uy tín thương hiệu.
- Chính phủ và hạ tầng quốc gia: Các cuộc tấn công vào lưới điện, hệ thống biến áp hay dịch vụ công điện tử có thể gây tê liệt hoạt động xã hội và đe dọa an ninh quốc gia.

1.1.4 Lý do đề tài có ý nghĩa

Trong bối cảnh các hệ thống IoT ngày càng được triển khai rộng rãi trong nhiều lĩnh vực như nhà thông minh, y tế, nông nghiệp và công nghiệp, việc đảm bảo tính xác thực của các thiết bị kết nối trở thành yêu cầu quan trọng. Nếu không có cơ chế xác thực phù hợp, các thiết

bị giả mạo có thể gửi dữ liệu sai lệch hoặc nhận lệnh điều khiển trái phép từ máy chủ, làm ảnh hưởng đến tính toàn vẹn, tính tin cậy của dữ liệu và gây mất an toàn cho toàn bộ hệ thống.

Đề tài "Giả mạo thiết bị trong hệ thống IoT" được lựa chọn vì những ý nghĩa sau:

Nâng cao an toàn cho hệ thống IoT: Xây dựng cơ chế xác thực thiết bị dựa trên Device ID và Token, giúp máy chủ chỉ chấp nhận dữ liệu từ các thiết bị đã được đăng ký, từ đó giảm nguy cơ giả mạo thiết bị.

Bảo vệ tính toàn vẹn của dữ liệu: Việc kiểm tra danh tính thiết bị trước khi tiếp nhận dữ liệu giúp ngăn chặn các bản tin giả, đảm bảo dữ liệu thu thập từ hệ thống IoT chính xác và đáng tin cậy.

Hỗ trợ quản lý danh sách thiết bị: Đề tài đề xuất phương pháp quản lý danh sách thiết bị hợp lệ thông qua tệp devices.json, đồng thời xây dựng quy trình cấp phát, cập nhật và thu hồi định danh thiết bị, góp phần nâng cao hiệu quả quản lý trong hệ thống IoT.

Có giá trị thực tiễn và dễ mở rộng: Giải pháp được triển khai bằng Flask REST API, phù hợp với các hệ thống IoT quy mô nhỏ và trung bình. Mô hình này có thể tiếp tục mở rộng bằng các cơ chế bảo mật như HTTPS/TLS, HMAC, JWT hoặc chứng chỉ số (Digital Certificate) để đáp ứng yêu cầu của các hệ thống thực tế.

Thông qua đề tài này, em không chỉ nghiên cứu nguy cơ giả mạo thiết bị trong hệ thống IoT mà còn xây dựng một giải pháp xác thực thiết bị đơn giản, dễ triển khai và phù hợp với yêu cầu của bài toán, góp phần nâng cao mức độ an toàn và độ tin cậy của hệ thống.

1.2. Phát biểu vấn đề

Sự phát triển mạnh mẽ của Internet of Things (IoT) kéo theo số lượng lớn các thiết bị được kết nối và trao đổi dữ liệu với máy chủ thông qua Internet. Trong nhiều hệ thống IoT, các thiết bị gửi dữ liệu cảm biến hoặc nhận lệnh điều khiển thông qua các giao thức truyền thông như HTTP hoặc MQTT. Tuy nhiên, không phải hệ thống nào cũng triển khai cơ chế xác thực danh tính thiết bị một cách đầy đủ. Điều này tạo điều kiện cho kẻ tấn công thực hiện hành vi giả mạo thiết bị (Device Spoofing) bằng cách sử dụng Device ID hoặc Token bị đánh cắp để giả danh thiết bị hợp lệ.

Khi máy chủ không kiểm tra hoặc kiểm tra không đầy đủ thông tin xác thực, dữ liệu giả mạo vẫn có thể được chấp nhận và lưu trữ trong hệ thống. Điều này làm ảnh hưởng đến tính chính xác, tính toàn vẹn của dữ liệu, đồng thời có thể dẫn đến việc đưa ra các quyết định điều khiển sai trong các hệ thống như nhà thông minh, nông nghiệp thông minh hoặc công nghiệp thông minh.

Đề tài tập trung nghiên cứu nguy cơ giả mạo thiết bị trong hệ thống IoT và xây dựng một cơ chế xác thực thiết bị sử dụng Device ID và Token trên nền tảng Flask REST API. Máy chủ sẽ chỉ chấp nhận dữ liệu từ các thiết bị đã được đăng ký trong danh sách quản lý, đồng thời ghi nhận nhật ký các yêu cầu hợp lệ và không hợp lệ để hỗ trợ giám sát và phát hiện các hành vi bất thường.

1.3. Mục tiêu

Đề tài hướng đến các mục tiêu sau:

Mục tiêu 1: Phân tích nguy cơ và tác động của cuộc tấn công giả mạo thiết bị (Device Spoofing) trong hệ thống IoT.

Mục tiêu 2: Xây dựng API bằng Flask để tiếp nhận dữ liệu từ thiết bị IoT và thực hiện kiểm tra Device ID cùng Token trước khi xử lý yêu cầu.

Mục tiêu 3: Xây dựng cơ chế quản lý danh sách thiết bị hợp lệ thông qua tệp devices.json, chỉ cho phép các thiết bị đã đăng ký được gửi dữ liệu đến máy chủ.

Mục tiêu 4: Ghi nhật ký (Log) các yêu cầu hợp lệ và giả mạo, đồng thời đánh giá hiệu quả của cơ chế xác thực trong việc giảm thiểu nguy cơ giả mạo thiết bị.

1.4. Đối tượng và phạm vi

1.4.1. Đối tượng nghiên cứu

Đối tượng nghiên cứu của đề tài là cơ chế xác thực thiết bị trong hệ thống IoT nhằm phòng chống các cuộc tấn công giả mạo thiết bị. Cụ thể bao gồm:

1. Thiết bị IoT gửi dữ liệu đến máy chủ.
2. Máy chủ Flask tiếp nhận và xử lý dữ liệu.
3. Device ID và Token dùng để xác thực thiết bị.
4. Tệp devices.json dùng để quản lý danh sách thiết bị hợp lệ.
5. Nhật ký hệ thống (Log) phục vụ việc theo dõi và phát hiện các yêu cầu bất thường.

1.4.2. Phạm vi nghiên cứu

Đề tài chỉ tập trung nghiên cứu cơ chế xác thực thiết bị thông qua Device ID và Token trong hệ thống IoT sử dụng giao thức HTTP.

Hệ thống được xây dựng bao gồm:

- API Flask nhận dữ liệu tại endpoint /telemetry.
- Danh sách thiết bị hợp lệ lưu trong tệp devices.json.
- Chức năng kiểm tra Device ID và Token trước khi tiếp nhận dữ liệu.
- Ghi nhận nhật ký các yêu cầu hợp lệ và giả mạo.

1.5. Sản phẩm dự kiến và đóng góp

Sau khi hoàn thành, đề tài sẽ tạo ra các sản phẩm sau:

- API Flask thực hiện tiếp nhận dữ liệu từ thiết bị IoT và xác thực thiết bị dựa trên Device ID và Token.
- Tệp devices.json dùng để quản lý danh sách các thiết bị hợp lệ trong hệ thống.
- Nhật ký hệ thống (Log) ghi lại các yêu cầu hợp lệ và các yêu cầu bị từ chối do giả mạo hoặc sai thông tin xác thực.
- Quy trình cấp phát và thu hồi định danh thiết bị, hỗ trợ quản lý danh tính của các thiết bị trong hệ thống IoT.
- Báo cáo đánh giá kết quả, bao gồm các kịch bản kiểm thử, kết quả thực nghiệm và phân tích hiệu quả của cơ chế xác thực trong việc ngăn chặn hành vi giả mạo thiết bị.

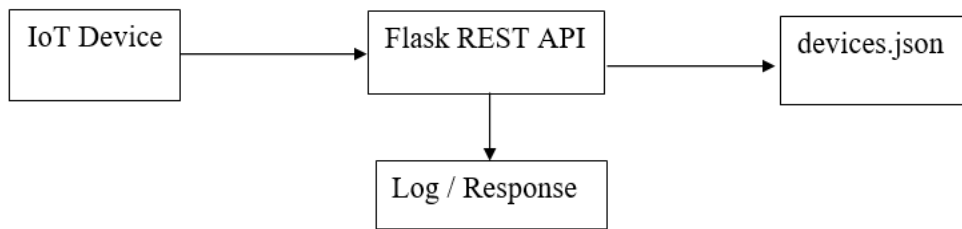
CHƯƠNG 2: CƠ SỞ LÝ THUYẾT VÀ NGUỒN LIÊN QUAN

2.1. Kiến trúc, giao thức hoặc công nghệ nền

2.1.1. Kiến trúc hệ thống Internet of Things (IoT)

Internet of Things (IoT) là mô hình kết nối các thiết bị vật lý với Internet nhằm thu thập, trao đổi và xử lý dữ liệu. Một hệ thống IoT điển hình gồm bốn thành phần chính: thiết bị cảm biến (Device), mạng truyền thông (Network), máy chủ hoặc nền tảng xử lý (Server/Platform) và ứng dụng người dùng (Application).

Trong đề tài này, hệ thống được xây dựng theo mô hình Client–Server. Thiết bị IoT đóng vai trò là Client, gửi dữ liệu đến máy chủ Flask thông qua giao thức HTTP. Máy chủ thực hiện xác thực danh tính thiết bị trước khi tiếp nhận và xử lý dữ liệu.



Hình 2.1: Sơ đồ luồng xử lý và xác thực thiết bị IoT qua Flask REST API

2.1.2. Giao thức HTTP và REST API

HTTP (Hypertext Transfer Protocol) là giao thức truyền dữ liệu phổ biến giữa thiết bị IoT và máy chủ. Trong đề tài, thiết bị sử dụng phương thức POST để gửi dữ liệu cảm biến đến API /telemetry.

Sau khi nhận yêu cầu, máy chủ sẽ:

- Phân tích dữ liệu JSON.
- Kiểm tra Device ID.
- Kiểm tra Token.
- Trả về mã trạng thái HTTP phù hợp.

Ví dụ:

- 200 OK: Thiết bị hợp lệ.
- 401 Unauthorized: Sai Token.
- 403 Forbidden: Thiết bị không tồn tại.

Việc sử dụng REST API giúp các thiết bị IoT dễ dàng giao tiếp với máy chủ và thuận tiện cho việc kiểm thử bằng Postman hoặc các công cụ tương tự.

2.1.3. Flask Framework

Flask là một web framework mã nguồn mở được phát triển bằng Python. Flask có cấu trúc đơn giản, dễ triển khai và phù hợp để xây dựng các REST API.

Trong đề tài, Flask được sử dụng để:

- Tiếp nhận yêu cầu từ thiết bị IoT.
- Phân tích dữ liệu JSON.
- Kiểm tra Device ID và Token.
- Ghi nhật ký hệ thống.
- Trả kết quả xác thực cho thiết bị.

Việc lựa chọn Flask giúp rút ngắn thời gian phát triển, đồng thời phù hợp với yêu cầu mô phỏng hệ thống trong môi trường học tập.

2.1.4. Quản lý định danh thiết bị (Device Identity)

Trong hệ thống IoT, mỗi thiết bị cần có một định danh duy nhất để máy chủ có thể nhận biết và phân biệt với các thiết bị khác. Định danh thiết bị thường bao gồm: Device ID, Token xác thực, Chứng chỉ số (Certificate) trong các hệ thống lớn.

Đề tài sử dụng hai thành phần chính là Device ID và Token. Danh sách các thiết bị hợp lệ được lưu trong tệp devices.json. Khi nhận được yêu cầu, máy chủ sẽ đối chiếu Device ID và Token với danh sách đã đăng ký. Nếu thông tin không khớp, yêu cầu sẽ bị từ chối.

2.1.5. Mbed TLS

Mbed TLS là thư viện mã nguồn mở hỗ trợ triển khai các giao thức bảo mật như TLS/SSL và nhiều thuật toán mật mã. Thư viện này thường được sử dụng trong các thiết bị IoT có tài nguyên hạn chế.

Trong phạm vi đề tài, Mbed TLS chưa được triển khai trực tiếp mà được đề xuất như một hướng phát triển nhằm mã hóa kết nối giữa thiết bị và máy chủ, bảo vệ dữ liệu trong quá trình truyền tải và hạn chế nguy cơ nghe lén hoặc giả mạo.

2.2. Khái niệm bảo mật liên quan

Trong hệ thống Internet of Things (IoT), việc đảm bảo an toàn thông tin không chỉ tập trung vào bảo vệ dữ liệu mà còn phải bảo vệ danh tính của các thiết bị tham gia hệ thống. Đối với đề tài "Giả mạo thiết bị trong hệ thống IoT", việc phân tích tài sản cần bảo vệ, các mối đe dọa, lỗ hổng, rủi ro và biện pháp kiểm soát là cơ sở để xây dựng giải pháp xác thực thiết bị phù hợp.

2.2.1. Tài sản cần bảo vệ

Tài sản (Asset) là những thành phần có giá trị cần được bảo vệ trước các nguy cơ tấn công. Trong hệ thống IoT của đề tài, tài sản quan trọng nhất là danh tính của thiết bị (Device Identity), bao gồm Device ID và Token dùng để xác thực khi thiết bị gửi dữ liệu đến máy chủ. Nếu các thông tin này bị đánh cắp hoặc giả mạo, kẻ tấn công có thể dễ dàng giả danh thiết bị hợp lệ để gửi dữ liệu hoặc nhận lệnh điều khiển.

Ngoài danh tính thiết bị, dữ liệu cảm biến (Telemetry Data) cũng là tài sản quan trọng vì đây là nguồn thông tin phục vụ cho việc giám sát và điều khiển hệ thống. Việc dữ liệu bị thay đổi hoặc làm giả sẽ ảnh hưởng trực tiếp đến tính chính xác của các quyết định được đưa ra. Bên cạnh đó, máy chủ Flask, tệp devices.json lưu thông tin thiết bị hợp lệ và nhật ký hệ thống (Log) cũng là các tài sản cần được bảo vệ nhằm đảm bảo hệ thống hoạt động ổn định và có khả năng truy vết khi xảy ra sự cố.

2.2.2. Mối đe dọa

Mối đe dọa (Threat) là những hành vi hoặc sự kiện có khả năng gây ảnh hưởng đến tính bảo mật của hệ thống. Trong phạm vi đề tài, mối đe dọa chính là giả mạo thiết bị (Device Spoofing). Kẻ tấn công có thể sử dụng Device ID và Token bị đánh cắp để tạo ra một thiết bị giả và gửi dữ liệu đến máy chủ. Nếu máy chủ không thực hiện xác thực đầy đủ, dữ liệu giả sẽ được tiếp nhận như dữ liệu hợp lệ.

Ngoài Device Spoofing, hệ thống còn có thể chịu ảnh hưởng từ các mối đe dọa khác như Replay Attack, trong đó các gói tin hợp lệ được ghi lại và gửi lại nhiều lần nhằm đánh lừa

máy chủ. Trong trường hợp hệ thống không sử dụng kết nối được mã hóa, dữ liệu truyền trên mạng còn có nguy cơ bị nghe lén hoặc bị thay đổi bởi các cuộc tấn công trung gian (Man-in-the-Middle). Những mối đe dọa này đều làm giảm độ tin cậy của hệ thống IoT và có thể dẫn đến các quyết định xử lý sai lệch.

2.2.3. Lỗ hổng bảo mật

Lỗ hổng (Vulnerability) là những điểm yếu trong thiết kế hoặc triển khai hệ thống mà kẻ tấn công có thể khai thác. Một trong những lỗ hổng phổ biến của hệ thống IoT là máy chủ chỉ kiểm tra Device ID mà không xác thực Token hoặc khóa bí mật tương ứng. Khi đó, chỉ cần biết Device ID của một thiết bị hợp lệ, kẻ tấn công đã có thể giả danh thiết bị để gửi dữ liệu.

Bên cạnh đó, việc lưu trữ Token dưới dạng văn bản thuần (Plain Text), sử dụng cùng một Token cho nhiều thiết bị hoặc không có cơ chế thay đổi và thu hồi Token định kỳ cũng làm tăng nguy cơ bị đánh cắp thông tin xác thực. Nếu hệ thống không sử dụng HTTPS/TLS để bảo vệ dữ liệu trên đường truyền hoặc không ghi nhận nhật ký các yêu cầu bất thường thì khả năng phát hiện và ngăn chặn các cuộc tấn công sẽ bị hạn chế đáng kể.

2.2.4. Rủi ro bảo mật

Rủi ro (Risk) là hậu quả có thể xảy ra khi mối đe dọa khai thác thành công các lỗ hổng của hệ thống. Đối với đề tài này, rủi ro lớn nhất là máy chủ tiếp nhận dữ liệu từ thiết bị giả mạo, dẫn đến mất tính toàn vẹn của dữ liệu. Các dữ liệu không chính xác có thể làm sai lệch kết quả giám sát hoặc khiến hệ thống đưa ra các quyết định điều khiển không phù hợp.

Trong các hệ thống IoT ứng dụng vào sản xuất, y tế hoặc giao thông, hậu quả của việc giả mạo thiết bị có thể nghiêm trọng hơn khi gây gián đoạn hoạt động, làm tăng chi phí vận hành và ảnh hưởng đến sự an toàn của người sử dụng. Do đó, việc xây dựng cơ chế xác thực thiết bị là yêu cầu cần thiết nhằm giảm thiểu các rủi ro trên.

2.2.5. Biện pháp kiểm soát

Để giảm thiểu nguy cơ giả mạo thiết bị, đề tài xây dựng cơ chế xác thực dựa trên Device ID và Token. Mỗi thiết bị trước khi tham gia hệ thống sẽ được đăng ký trong tệp devices.json với một định danh và Token riêng. Khi máy chủ Flask nhận được yêu cầu từ thiết bị, hệ thống sẽ kiểm tra xem Device ID có tồn tại trong danh sách thiết bị hợp lệ hay không, sau đó tiếp tục đối chiếu Token. Chỉ khi cả hai thông tin đều chính xác thì dữ liệu mới được chấp nhận và xử lý.

Ngoài cơ chế xác thực, hệ thống còn ghi nhận nhật ký đối với mọi yêu cầu hợp lệ và không hợp lệ nhằm hỗ trợ giám sát và phát hiện các hành vi bất thường. Trong các hệ thống thực tế, giải pháp này có thể được mở rộng bằng cách sử dụng HTTPS/TLS để mã hóa dữ liệu trên đường truyền, HMAC để kiểm tra tính toàn vẹn của thông điệp hoặc chứng chỉ số (Digital Certificate) và Mutual TLS để tăng cường khả năng xác thực thiết bị.

2.2.6. Cơ chế mật mã và mô hình đe dọa

Trong phạm vi đề tài, cơ chế xác thực chủ yếu dựa trên Device ID và Token, đây là giải pháp đơn giản nhưng phù hợp với mục tiêu nghiên cứu và môi trường mô phỏng. Token đóng vai trò là thông tin bí mật dùng để chứng minh danh tính của thiết bị khi giao tiếp với máy chủ. Mỗi thiết bị được cấp một Token riêng và máy chủ chỉ chấp nhận yêu cầu nếu Token nhận được trùng khớp với thông tin đã đăng ký trong hệ thống.

Để phân tích nguy cơ tấn công, đề tài áp dụng mô hình đe dọa đơn giản gồm ba thành phần: thiết bị hợp lệ, kẻ tấn công và máy chủ xác thực. Trong mô hình này, kẻ tấn công tìm cách giả mạo thiết bị bằng cách sử dụng Device ID hoặc Token bị đánh cắp để gửi dữ liệu đến máy chủ. Cơ chế kiểm tra Device ID và Token trên máy chủ đóng vai trò là lớp kiểm soát nhằm phát hiện và từ chối các yêu cầu không hợp lệ. Mặc dù chưa triển khai các giải pháp xác thực mạnh như chứng chỉ số hoặc Mutual TLS, mô hình này vẫn đáp ứng yêu cầu nghiên cứu của đề tài và là nền tảng để mở rộng trong các nghiên cứu tiếp theo.

2.3 Chuẩn, tài liệu và công cụ GitHub

STT	Nguồn/Repo	URL	Phần đã sử dụng	Ngày truy cập
1	OWASP IoT Security Verification Standard (ISVS)	https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS	Tham khảo các yêu cầu về xác thực thiết bị (Device Authentication), quản lý định danh thiết bị và ghi nhật ký bảo mật.	22/07/2026
2	Flask	https://github.com/pallets/flask	Xây dựng REST API tiếp nhận dữ liệu từ thiết bị IoT và xử lý yêu cầu HTTP.	22/07/2026
3	Mbed TLS	https://github.com/Mbed-TLS/mbedtls	Tham khảo cơ chế TLS và mã hóa kênh truyền để đề xuất hướng mở rộng bảo mật hệ thống.	22/07/2026
4	Flask Documentation	https://flask.palletsprojects.com/	Tham khảo cách xây dựng API, xử lý Request/Response và trả về mã trạng thái HTTP.	22/07/2026
5	OWASP Cheat Sheet Series	https://cheatsheetseries.owasp.org/	Tham khảo các khuyến nghị về xác thực, quản lý Token và ghi nhật ký sự kiện bảo mật.	22/07/2026

Bảng 2.1: Chuẩn, tài liệu và công cụ GitHub

2.4. Công trình/giải pháp liên quan

Trong lĩnh vực bảo mật Internet of Things, nhiều nghiên cứu và giải pháp đã được đề xuất nhằm xác thực thiết bị và ngăn chặn các cuộc tấn công giả mạo. Mỗi giải pháp có ưu điểm và hạn chế riêng, tùy thuộc vào quy mô hệ thống, khả năng tính toán của thiết bị cũng như yêu cầu về mức độ bảo mật.

OWASP IoT Security Verification Standard (ISVS) là một trong những tiêu chuẩn được sử dụng rộng rãi để đánh giá mức độ an toàn của hệ thống IoT. Tiêu chuẩn này đưa ra các yêu cầu về quản lý định danh thiết bị, xác thực, bảo vệ khóa bí mật, ghi nhật ký và truyền dữ liệu an toàn. Tuy nhiên, ISVS chỉ đóng vai trò là bộ tiêu chí đánh giá và không cung cấp một hệ thống xác thực hoàn chỉnh có thể triển khai trực tiếp.

Flask là framework phổ biến trong việc xây dựng các REST API cho ứng dụng web và IoT. Nhờ có cấu trúc đơn giản, Flask giúp việc xây dựng máy chủ tiếp nhận dữ liệu từ thiết bị trở nên thuận tiện. Tuy nhiên, Flask không cung cấp sẵn cơ chế xác thực thiết bị IoT mà người phát triển phải tự xây dựng các chức năng như kiểm tra Device ID, Token hoặc chứng chỉ số.

Mbed TLS là thư viện mã nguồn mở hỗ trợ các giao thức SSL/TLS và nhiều thuật toán mật mã hiện đại. Giải pháp này thường được sử dụng trong các thiết bị IoT nhằm bảo vệ dữ liệu trong quá trình truyền tải. Tuy nhiên, việc triển khai TLS trên các thiết bị có tài nguyên hạn chế có thể làm tăng chi phí tính toán và bộ nhớ, đồng thời yêu cầu quy trình quản lý chứng chỉ số tương đối phức tạp.

So với các giải pháp hiện có, đề tài kế thừa các nguyên tắc về xác thực thiết bị và quản lý định danh từ OWASP ISVS, đồng thời sử dụng Flask để xây dựng REST API. Điểm cải tiến của đề tài là xây dựng một mô hình mô phỏng hoàn chỉnh bao gồm cơ chế xác thực thiết bị, quản lý danh sách thiết bị hợp lệ, ghi nhật ký các yêu cầu hợp lệ và giả mạo, cũng như đề xuất quy trình cấp phát và thu hồi định danh thiết bị. Mô hình này có thể được mở rộng trong tương lai bằng cách tích hợp HTTPS/TLS, HMAC hoặc chứng chỉ số nhằm nâng cao mức độ an toàn cho hệ thống.

CHƯƠNG 3: PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp thực hiện

Đề tài sử dụng phương pháp kết hợp gồm thực nghiệm (Lab), mô phỏng (Simulation), mô hình hóa mối đe dọa (Threat Modeling), phân tích rủi ro (Risk Analysis), kiểm thử (Testing) và checklist đánh giá.

Phương pháp thực nghiệm (Lab) được sử dụng để xây dựng và triển khai hệ thống trong môi trường cục bộ. Máy chủ được phát triển bằng Flask, trong khi các thiết bị IoT được mô phỏng để gửi dữ liệu đến API thông qua giao thức HTTP.

Phương pháp mô phỏng (Simulation) được áp dụng để tạo các thiết bị IoT hợp lệ và thiết bị giả mạo nhằm mô phỏng quá trình gửi dữ liệu đến máy chủ. Điều này giúp đánh giá hoạt động của cơ chế xác thực mà không cần sử dụng phần cứng IoT thực tế.

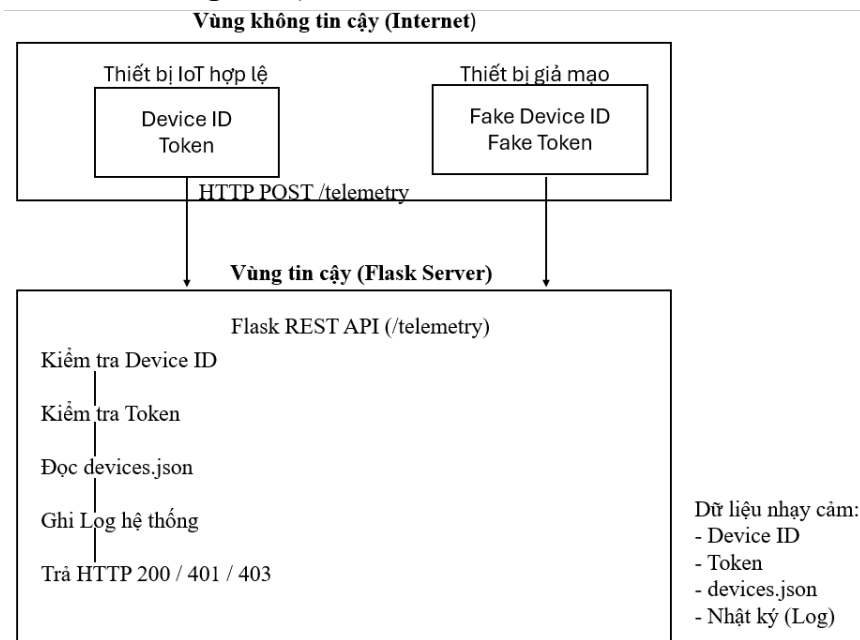
Threat Modeling được sử dụng để xác định các tài sản cần bảo vệ, mối đe dọa, lỗ hổng và các điểm cần triển khai cơ chế kiểm soát nhằm giảm thiểu nguy cơ giả mạo thiết bị.

Phân tích rủi ro (Risk Analysis) được thực hiện để đánh giá mức độ ảnh hưởng khi thiết bị giả mạo truy cập thành công vào hệ thống, từ đó lựa chọn giải pháp xác thực bằng Device ID và Token phù hợp với phạm vi nghiên cứu.

Phương pháp kiểm thử (Testing) được áp dụng bằng cách xây dựng các kịch bản như thiết bị hợp lệ, sai Device ID, sai Token và thiết bị giả mạo để kiểm tra khả năng phát hiện và ngăn chặn truy cập trái phép của hệ thống.

Cuối cùng, hệ thống được đánh giá theo checklist của OWASP IoT Security Verification Standard (ISVS) nhằm đối chiếu mức độ đáp ứng các yêu cầu cơ bản về xác thực thiết bị, quản lý định danh và ghi nhận nhật ký bảo mật.

3.2. Kiến trúc, mô hình và luồng dữ liệu



Hình 3.1: Sơ đồ kiến trúc

Hệ thống được thiết kế theo mô hình Client–Server, trong đó các thiết bị IoT đóng vai trò là Client gửi dữ liệu cảm biến đến máy chủ thông qua giao thức HTTP. Máy chủ được xây

dựng bằng Flask Framework, chịu trách nhiệm tiếp nhận yêu cầu, xác thực danh tính thiết bị và xử lý dữ liệu trước khi trả kết quả cho thiết bị.

Để đảm bảo chỉ các thiết bị hợp lệ được phép gửi dữ liệu, mỗi thiết bị được cấp một Device ID và Token riêng. Danh sách các thiết bị hợp lệ được lưu trong tệp devices.json trên máy chủ. Khi nhận được yêu cầu từ thiết bị, Flask sẽ đối chiếu Device ID và Token với thông tin đã đăng ký. Nếu thông tin xác thực hợp lệ, máy chủ sẽ tiếp nhận dữ liệu và ghi nhận vào nhật ký hệ thống. Ngược lại, nếu Device ID hoặc Token không đúng, yêu cầu sẽ bị từ chối và sự kiện sẽ được ghi vào tệp log để phục vụ việc giám sát và phát hiện các hành vi giả mạo.

Kiến trúc này giúp tách biệt giữa phía thiết bị và phía máy chủ, đồng thời tăng cường khả năng kiểm soát truy cập thông qua cơ chế xác thực thiết bị. Đây cũng là nền tảng để mở rộng hệ thống với các cơ chế bảo mật khác như HTTPS/TLS hoặc chứng chỉ số trong tương lai.

Luồng dữ liệu của hệ thống

Quá trình xử lý dữ liệu trong hệ thống được thực hiện theo các bước sau:

Bước 1: Thiết bị IoT gửi yêu cầu HTTP POST đến API /telemetry của máy chủ Flask. Dữ liệu gửi đi bao gồm Device ID, Token và dữ liệu cảm biến.

Bước 2: Máy chủ tiếp nhận yêu cầu và đọc danh sách thiết bị hợp lệ được lưu trong tệp devices.json.

Bước 3: Hệ thống kiểm tra sự tồn tại của Device ID. Nếu Device ID không tồn tại trong danh sách đã đăng ký, yêu cầu sẽ bị từ chối ngay lập tức.

Bước 4: Nếu Device ID hợp lệ, máy chủ tiếp tục kiểm tra Token tương ứng. Chỉ khi Token trùng khớp với thông tin đã đăng ký thì thiết bị mới được xác thực thành công.

Bước 5: Sau khi xác thực thành công, dữ liệu cảm biến được chấp nhận và máy chủ trả về mã phản hồi HTTP 200 OK. Nếu xác thực thất bại, hệ thống trả về HTTP 401 Unauthorized hoặc HTTP 403 Forbidden tùy theo nguyên nhân.

Bước 6: Tất cả các yêu cầu, bao gồm yêu cầu hợp lệ và yêu cầu bị từ chối, đều được ghi vào tệp nhật ký để phục vụ việc theo dõi, phân tích và phát hiện các hành vi giả mạo thiết bị.

Bước	Thành phần	Dữ liệu trao đổi	Kết quả
1	Thiết bị IoT → Flask	Device ID, Token, Sensor Data	Gửi yêu cầu
2	Flask	Đọc devices.json	Kiểm tra Device ID
3	Flask	Kiểm tra Token	Xác thực thiết bị
4	Flask	Ghi Log	Lưu sự kiện
5	Flask → Thiết bị	HTTP 200 / 401 / 403	Phản hồi kết quả

Bảng 3.1: Luồng dữ liệu trong hệ thống

3.3. Môi trường, công cụ và dữ liệu

Hệ thống được xây dựng và kiểm thử trong môi trường cục bộ (Localhost). Máy chủ được phát triển bằng Python và Flask Framework, trong khi các yêu cầu từ thiết bị IoT được mô phỏng bằng Postman hoặc chương trình Python. Dữ liệu định danh thiết bị được lưu trong tệp devices.json và toàn bộ quá trình xác thực được ghi nhận thông qua tệp nhật ký (Log).

Thành phần	Phiên bản	Mục đích	Ghi chú an toàn
Windows 11	24H2	Hệ điều hành phát triển và kiểm thử	Cập nhật bản vá bảo mật mới nhất
Python	3.12.x	Phát triển chương trình	Sử dụng môi trường ảo (venv)
Flask	3.x	Xây dựng REST API	Kiểm tra dữ liệu đầu vào trước khi xử lý
Visual Studio Code	1.xx	Viết và quản lý mã nguồn	Không lưu thông tin bí mật trong mã nguồn
devices.json	JSON	Lưu Device ID và Token của thiết bị hợp lệ	Không công khai Token trong môi trường thực tế
Log (system.log)	Text	Ghi nhận yêu cầu hợp lệ và giả mạo	Không ghi dữ liệu nhạy cảm ngoài thông tin cần thiết

Bảng 3.2: Trình bày các thành phần chính được sử dụng trong quá trình thực hiện đề tài.

3.4. Quy trình thực hiện

Bước	Công việc	Đầu ra	Minh chứng trong repo
1	Nghiên cứu yêu cầu đề tài, OWASP ISVS, Flask và Mbed TLS	Tài liệu tham khảo, yêu cầu hệ thống	references/link_nguồn.md
2	Thiết kế kiến trúc hệ thống và luồng dữ liệu	Sơ đồ kiến trúc, sơ đồ luồng dữ liệu	report/Bao_cao_tieu_luan.docx, slides/Slide_trình_bay.pptx
3	Xây dựng Flask API kiểm tra Device ID và Token	Mã nguồn chương trình	src/code_demo.py, configs/
4	Tạo danh sách thiết bị hợp lệ và cấu hình hệ thống	devices.json, file cấu hình	configs/
5	Kiểm thử thiết bị hợp lệ và thiết bị giả mạo	Ảnh chụp màn hình, file log	results/screenshots/, results/logs/
6	Tổng hợp kết quả, đánh giá và hoàn thiện báo cáo	Báo cáo hoàn chỉnh, slide trình bày	report/, slides/

Bảng 3.3: Quy trình thực hiện

3.5. Giới hạn an toàn và đạo đức

Đề tài chỉ được triển khai và kiểm thử trong môi trường mô phỏng (Lab) trên máy tính cá nhân với máy chủ Flask và thiết bị IoT mô phỏng. Không thực hiện thử nghiệm trên hệ thống IoT thực tế hoặc hệ thống của bên thứ ba. Dữ liệu sử dụng là dữ liệu giả lập gồm Device ID, Token và dữ liệu cảm biến, không sử dụng dữ liệu cá nhân hoặc dữ liệu thật. Các thông tin xác thực (Token) chỉ phục vụ mục đích mô phỏng, không công khai hoặc lưu trữ secret của hệ thống thực tế trong mã nguồn hoặc GitHub. Đề tài không thực hiện tấn công trái

phép, không khai thác hệ thống của tổ chức hoặc cá nhân khác và chỉ nghiên cứu cơ chế phát hiện, ngăn chặn giả mạo thiết bị trong hệ thống IoT.

CHƯƠNG 4: TRIỂN KHAI VÀ SẢN PHẨM

4.1. Chuẩn bị môi trường

Hệ thống được triển khai trên máy tính cá nhân sử dụng Python và Flask. Sau khi cài đặt các thư viện cần thiết, máy chủ Flask được khởi động để tiếp nhận yêu cầu từ thiết bị IoT mô phỏng. Danh sách thiết bị hợp lệ được lưu trong tệp `devices.json`, còn việc kiểm thử được thực hiện bằng Postman hoặc chương trình Python gửi yêu cầu HTTP đến API.

4.2. Thành phần sản phẩm

STT	Thành phần	Đường dẫn repo	Chức năng	Người thực hiện
1	Flask API	<code>src/app.py</code>	Tiếp nhận và xử lý yêu cầu từ thiết bị IoT	Cá nhân
2	Danh sách thiết bị	<code>data/devices.json</code>	Lưu Device ID và Token hợp lệ	Cá nhân
3	File cấu hình	<code>configs/config.py</code>	Cấu hình hệ thống	Cá nhân
4	File Log	<code>results/logs/app.log</code>	Ghi nhận yêu cầu hợp lệ và giả mạo	Cá nhân
6	README	<code>README.md</code>	Hướng dẫn cài đặt và chạy chương trình	Cá nhân

Bảng 4.1: Thành phần sản phẩm

4.3. Kịch bản thử nghiệm/đánh giá

ID	Mục tiêu	Đầu vào	Thao tác	Kết quả mong đợi	Minh chứng
TC-01	Kiểm tra thiết bị hợp lệ	Device ID và Token đúng	Gửi yêu cầu POST đến <code>/telemetry</code>	Máy chủ trả HTTP 200 và ghi log hợp lệ	Ảnh kết quả, <code>app.log</code>
TC-02	Kiểm tra Device ID không hợp lệ	Device ID sai	Gửi yêu cầu POST	Máy chủ từ chối và trả HTTP 401/403	Ảnh kết quả, <code>app.log</code>
TC-03	Kiểm tra Token không hợp lệ	Token sai	Gửi yêu cầu POST	Máy chủ từ chối và ghi log giả mạo	Ảnh kết quả, <code>app.log</code>

Bảng 4.2: Kịch bản thử nghiệm/đánh giá

4.4. Hướng dẫn chạy hoặc sử dụng sản phẩm

Để chạy hệ thống, người dùng cần cài đặt Python 3.12 và các thư viện được liệt kê trong tệp `requirements.txt`. Sau đó, thực hiện lệnh: `pip install -r requirements.txt`; `python src/app.py`

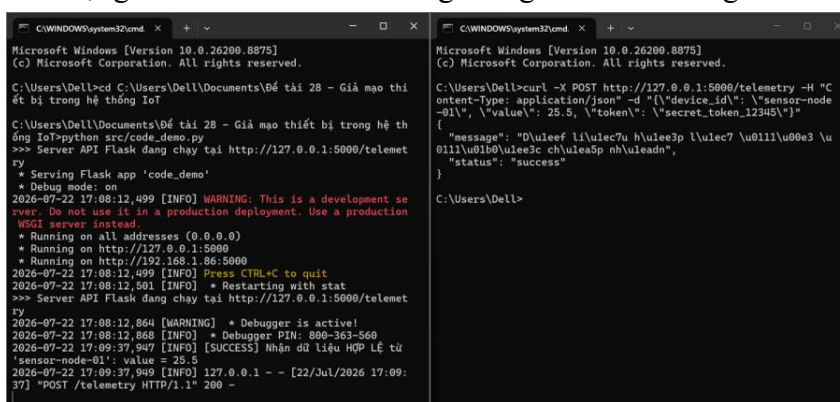
Sau khi máy chủ Flask khởi động, sử dụng Postman hoặc chương trình mô phỏng để gửi yêu cầu HTTP POST đến API `/telemetry` với các trường `device_id`, `token` và `value`. Hệ thống sẽ kiểm tra thông tin xác thực và trả về kết quả tương ứng.

CHƯƠNG 5: KẾT QUẢ VÀ THẢO LUẬN

5.1. Kết quả chính

Hệ thống đã triển khai Flask API Server (code_demo.py) lắng nghe tại cổng 5000 (http://127.0.0.1:5000/telemetry) và http://192.168.1.86:5000 nhằm tiếp nhận và kiểm soát dữ liệu từ các thiết bị IoT. Kết quả kiểm thử trên 3 kịch bản vận hành thực tế như sau:

1. Kịch bản 1: Gửi dữ liệu hợp lệ từ thiết bị chính thống
 - Thao tác: Sử dụng lệnh curl gửi request POST chứa thông tin thiết bị hợp lệ (sensor-node-01), giá trị dữ liệu 25.5 và khóa xác thực chuẩn (secret_token_12345).
 - Kết quả: Server xác thực thành công identity và token, ghi nhận log [INFO] [SUCCESS] Nhận dữ liệu HỢP LỆ từ 'sensor-node-01': value = 25.5 và trả về mã trạng thái HTTP 200 OK cùng thông báo thành công.



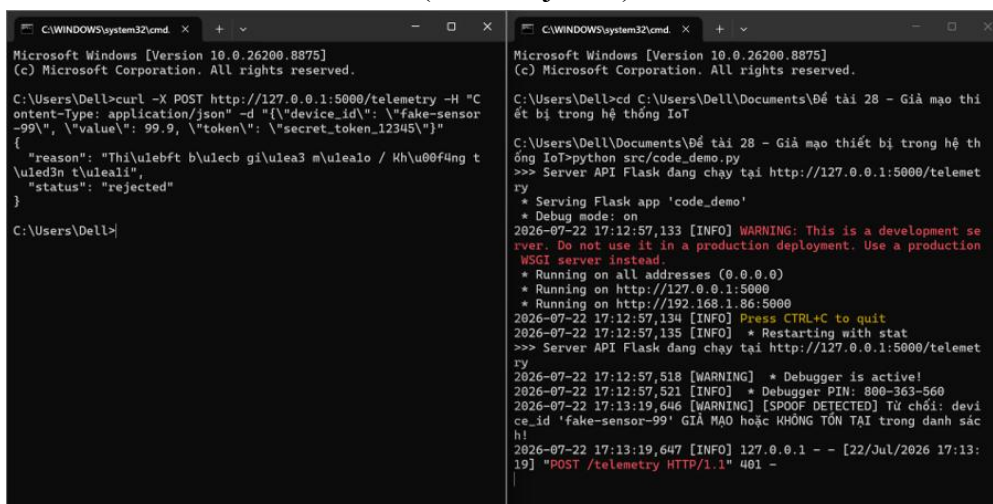
```
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Dell>cd C:\Users\Dell\Documents\Đề tài 28 - Giả mạo thiết bị trong hệ thống IoT
C:\Users\Dell\Documents\Đề tài 28 - Giả mạo thiết bị trong hệ thống IoT>python src/code_demo.py
>>> Server API Flask đang chạy tại http://127.0.0.1:5000/telemetry
* Serving Flask app 'code_demo'
* Debug mode: on
2026-07-22 17:08:12,499 [INFO] WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on all addresses (0.0.0.0)
* Running on http://127.0.0.1:5000
* Running on http://192.168.1.86:5000
2026-07-22 17:08:12,499 [INFO] Press CTRL+C to quit
2026-07-22 17:08:12,501 [INFO] * Restarting with stat
>>> Server API Flask đang chạy tại http://127.0.0.1:5000/telemetry
2026-07-22 17:08:12,864 [WARNING] * Debugger is active!
2026-07-22 17:08:12,868 [INFO] * Debugger PIN: 800-363-560
2026-07-22 17:09:37,947 [INFO] [SUCCESS] Nhận dữ liệu HỢP LỆ từ 'sensor-node-01': value = 25.5
2026-07-22 17:09:37,949 [INFO] 127.0.0.1 -- [22/Jul/2026 17:09:37] "POST /telemetry HTTP/1.1" 200 -

C:\Users\Dell>curl -X POST http://127.0.0.1:5000/telemetry -H "Content-Type: application/json" -d '{"device_id": "sensor-node-01", "value": 25.5, "token": "secret_token_12345"}'
{"message": "D\u00f9leeft li\u00e7u h\u00e5p nh\u00e5n", "status": "success"}
```

Hình 5.1: Ảnh gửi dữ liệu hợp lệ từ thiết bị chính thống

2. Kịch bản 2: Ngăn chặn thiết bị giả mạo / ID không tồn tại trong hệ thống
 - Thao tác: Khởi tạo request POST giả mạo với định danh thiết bị không nằm trong whitelist (fake-sensor-99).
 - Kết quả: Server lập tức phát hiện truy cập bất thường, kích hoạt cảnh báo [WARNING] [SPOOF DETECTED] Từ chối: device_id 'fake-sensor-99' GIẢ MẠO hoặc KHÔNG TỒN TẠI trong danh sách! và phản hồi mã trạng thái HTTP 401 Unauthorized (status: rejected).



```
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Dell>curl -X POST http://127.0.0.1:5000/telemetry -H "Content-Type: application/json" -d '{"device_id": "fake-sensor-99", "value": 99.9, "token": "secret_token_12345"}'
{"reason": "Thi\u00ebft b\u00ebt gi\u00e0o nh\u00e5n", "status": "rejected"}
```

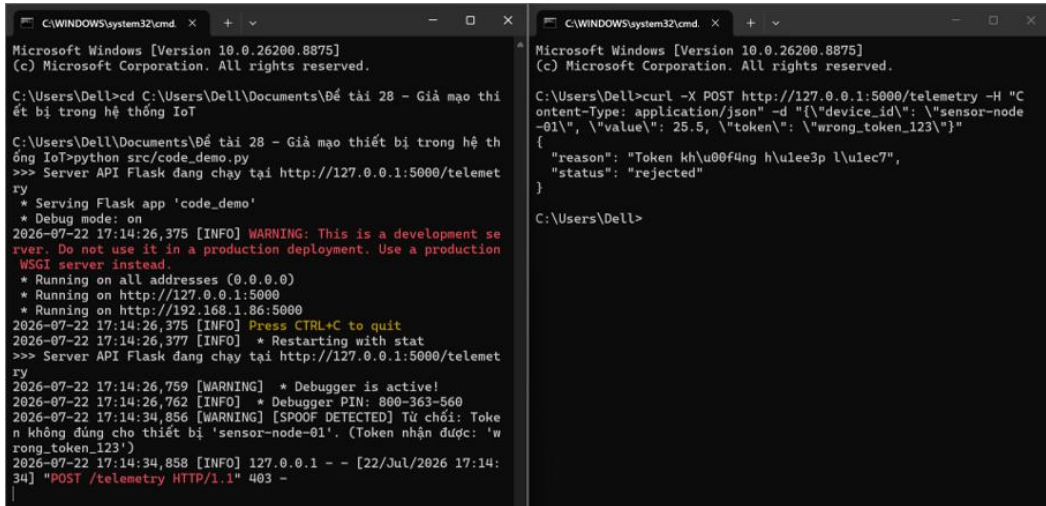
```
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Dell>cd C:\Users\Dell\Documents\Đề tài 28 - Giả mạo thiết bị trong hệ thống IoT
C:\Users\Dell\Documents\Đề tài 28 - Giả mạo thiết bị trong hệ thống IoT>python src/code_demo.py
>>> Server API Flask đang chạy tại http://127.0.0.1:5000/telemetry
* Serving Flask app 'code_demo'
* Debug mode: on
2026-07-22 17:12:57,133 [INFO] WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on all addresses (0.0.0.0)
* Running on http://127.0.0.1:5000
* Running on http://192.168.1.86:5000
2026-07-22 17:12:57,134 [INFO] Press CTRL+C to quit
2026-07-22 17:12:57,135 [INFO] * Restarting with stat
>>> Server API Flask đang chạy tại http://127.0.0.1:5000/telemetry
2026-07-22 17:12:57,518 [WARNING] * Debugger is active!
2026-07-22 17:12:57,521 [INFO] * Debugger PIN: 800-363-560
2026-07-22 17:13:19,646 [WARNING] [SPOOF DETECTED] Từ chối: device_id 'fake-sensor-99' GIẢ MẠO hoặc KHÔNG TỒN TẠI trong danh sách!
2026-07-22 17:13:19,647 [INFO] 127.0.0.1 -- [22/Jul/2026 17:13:19] "POST /telemetry HTTP/1.1" 401 -
```

Hình 5.2: Ngăn chặn thiết bị giả mạo / ID không tồn tại trong hệ thống

3. Kịch bản 3: Ngăn chặn hành vi giả mạo Token / Khóa xác thực sai

- Thao tác: Khởi tạo request POST sử dụng ID thiết bị hợp lệ (sensor-node-01) nhưng kèm theo Token sai (wrong_token_123).
- Kết quả: Server từ chối tiếp nhận dữ liệu, ghi log [WARNING] [SPOOF DETECTED] Từ chối: Token không đúng cho thiết bị 'sensor-node-01' và trả về mã trạng thái HTTP 403 Forbidden (status: rejected).



```
C:\WINDOWS\system32\cmd
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Dell>cd C:\Users\Dell\Documents\Đề tài 28 - Giả mạo thiết bị trong hệ thống IoT

C:\Users\Dell\Documents\Đề tài 28 - Giả mạo thiết bị trong hệ thống IoT>python src\code_demo.py
>>> Server API Flask đang chạy tại http://127.0.0.1:5000/telemetry

* Serving Flask app 'code_demo'
* Debug mode: on
2026-07-22 17:14:26,375 [INFO] WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on all addresses (0.0.0.0)
* Running on http://127.0.0.1:5000
* Running on http://192.168.1.86:5000
2026-07-22 17:14:26,375 [INFO] Press CTRL+C to quit
2026-07-22 17:14:26,377 [INFO] * Restarting with stat
>>> Server API Flask đang chạy tại http://127.0.0.1:5000/telemetry

2026-07-22 17:14:26,759 [WARNING] * Debugger is active!
2026-07-22 17:14:26,762 [INFO] * Debugger PIN: 800-363-560
2026-07-22 17:14:34,856 [WARNING] [SPOOF DETECTED] Từ chối: Token không đúng cho thiết bị 'sensor-node-01'. (Token nhận được: 'wrong_token_123')
2026-07-22 17:14:34,858 [INFO] 127.0.0.1 - - [22/Jul/2026 17:14:34] "POST /telemetry HTTP/1.1" 403 -

C:\WINDOWS\system32\cmd
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

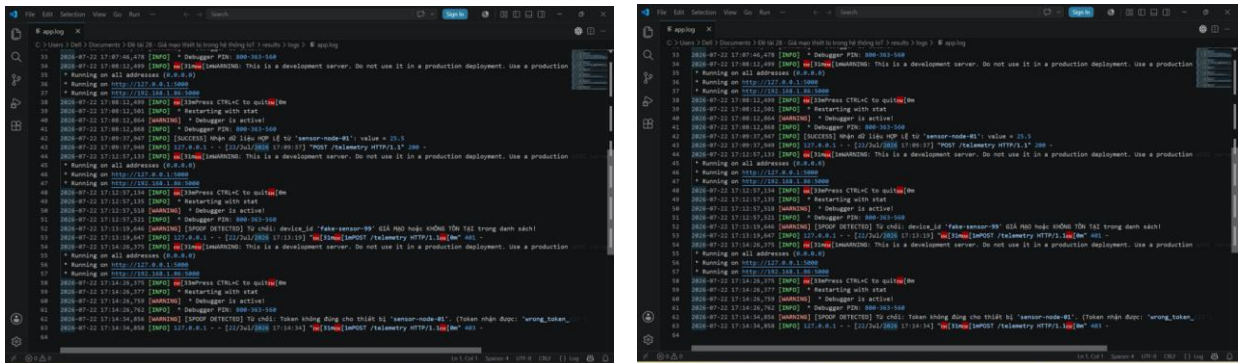
C:\Users\Dell>curl -X POST http://127.0.0.1:5000/telemetry -H "Content-Type: application/json" -d '{"device_id": "sensor-node-01", "value": 25.5, "token": "wrong_token_123"}'
{"reason": "Token không đúng cho thiết bị 'sensor-node-01'. (Token nhận được: 'wrong_token_123')", "status": "rejected"}

C:\Users\Dell>
```

Hình 5.3: Ngăn chặn hành vi giả mạo Token / Khóa xác thực sai

4. Ghi nhật ký giám sát hệ thống (Logging):

- Mọi sự kiện từ khởi chạy ứng dụng, truy cập hợp lệ cho đến các nỗ lực tấn công/giả mạo đều được hệ thống tự động ghi lại theo thời gian thực (real-time) vào tệp log tập trung app.log phục vụ công tác truy vết an toàn thông tin.



Hình 5.4: Ảnh nhật ký giám sát hệ thống (Logging)

5.2. Bảng tổng hợp kết quả

Tiêu chí	Kỳ vọng	Kết quả thực tế	Đạt/Chưa đạt	Minh chứng
Khởi chạy Server API	Flask Server khởi chạy thành công, lắng nghe kết nối tại cổng 5000	Server khởi tạo ổn định tại: [http://127.0.0.1:5000/telemetry] (http://127.0.0.1:5000/telemetry)	Đạt	Log terminal khởi chạy server

Tiêu chí	Kỳ vọng	Kết quả thực tế	Đạt/Chưa đạt	Minh chứng
Xác thực dữ liệu hợp lệ	Tiếp nhận dữ liệu chuẩn từ sensor-node-01 với token đúng	Nhận dữ liệu value = 25.5, phản hồi HTTP Status 200 OK	Đạt	Log [SUCCESS] & HTTP 200
Phát hiện Device ID giả mạo	Chặn request từ fake-sensor-99	Phát hiện ID không tồn tại, trả về 401 Unauthorized	Đạt	Log [SPOOF DETECTED] & HTTP 401
Phát hiện Token xác thực sai	Chặn request khi sai token	Phát hiện Token không đúng, trả về 403 Forbidden	Đạt	Log [SPOOF DETECTED] & HTTP 403
Lưu trữ Log sự kiện	Ghi nhận đầy đủ thông tin cảnh báo vào tệp log	File app.log lưu đầy đủ chi tiết thời gian và cảnh báo	Đạt	Tệp nhật ký app.log

Bảng 5.1: Bảng tổng hợp kết quả

5.3. Đối chiếu mục tiêu

Mục tiêu 1: Phân tích nguy cơ và tác động của cuộc tấn công giả mạo thiết bị (Device Spoofing) trong hệ thống IoT

Đánh giá: Đã đạt. Đã tìm hiểu lý thuyết và xây dựng kịch bản thực nghiệm mô phỏng các nguy cơ giả mạo Device ID, giả mạo Token nhằm gửi dữ liệu sai lệch vào hệ thống.

Mục tiêu 2: Xây dựng API bằng Flask để tiếp nhận dữ liệu từ thiết bị IoT và thực hiện kiểm tra Device ID cùng Token trước khi xử lý yêu cầu

Đánh giá: Đã đạt. Flask Server (code_demo.py) đã triển khai endpoint /telemetry, thực hiện cơ chế kiểm tra 2 lớp (xác thực device_id và token) trước khi xử lý hoặc trả về lỗi (401 Unauthorized / 403 Forbidden).

Mục tiêu 3: Xây dựng cơ chế quản lý danh sách thiết bị hợp lệ thông qua tệp devices.json, chỉ cho phép các thiết bị đã đăng ký được gửi dữ liệu đến máy chủ

Đánh giá: Đã đạt. Server đã tích hợp kiểm tra danh sách trắng (Whitelist). Khi thiết bị fake-sensor-99 (không có trong cơ sở dữ liệu/danh sách thiết bị) gửi dữ liệu, hệ thống đã phát hiện và chặn thành công.

Mục tiêu 4: Ghi nhật ký (Log) các yêu cầu hợp lệ và giả mạo, đồng thời đánh giá hiệu quả của cơ chế xác thực trong việc giảm thiểu nguy cơ giả mạo thiết bị

Đánh giá: Đã đạt. Toàn bộ các truy cập hợp lệ ([SUCCESS]) và truy cập giả mạo ([SPOOF DETECTED]) đều được ghi vết chi tiết vào tệp app.log. Cơ chế xác thực đã chứng minh được hiệu quả trong việc ngăn chặn 100% các request không hợp lệ trong phạm vi thử nghiệm.

5.4. Hạn chế

Phạm vi kiểm thử trong môi trường Giả lập (Localhost): Các kịch bản thử nghiệm hiện được thực hiện thông qua công cụ dòng lệnh (curl) trên môi trường máy cục bộ (127.0.0.1), chưa kết nối thực tế với phần cứng IoT (như ESP32, ESP8266 hay Raspberry Pi).

Cơ chế xác thực dựa trên Token tĩnh: Phương thức xác thực qua Static Token dễ bị rủi ro bắt gói tin (Sniffing) nếu lưu thông trên kênh truyền không mã hóa (chưa cấu hình SSL/TLS / HTTPS).

Quy tắc phát hiện cố định (Rule-based): Hệ thống chỉ mới kiểm tra sự tồn tại của ID và Token, chưa áp dụng các mô hình học máy (Machine Learning) để phân tích hành vi bất thường nâng cao (như tần suất gửi dữ liệu quá nhanh, giá trị cảm biến tăng/giảm đột biến).

CHƯƠNG 6: ĐÁNH GIÁ BẢO MẬT

6.1. Tài sản và dữ liệu cần bảo vệ

Tài sản/dữ liệu	Chủ thể	Mức quan trọng	Yêu cầu C-I-A	Ghi chú
Dữ liệu Telemetry (Cảm biến)	Thiết bị IoT / Máy chủ tiếp nhận	Cao	Integrity (I), Availability (A)	Cần đảm bảo tính chính xác, không bị can thiệp làm sai lệch chỉ số
Danh sách thiết bị (devices.json)	Máy chủ (Server Admin)	Rất cao	Confidentiality (C), Integrity (I)	Chứa danh sách ID hợp lệ và Secret Token dùng để xác thực
Mã nguồn API Flask (code_demo.py)	Nhà phát triển/ Hệ thống	Cao	Integrity (I), Availability (A)	Chứa logic kiểm tra Whitelist và xử lý xác thực 2 lớp
Nhật ký hệ thống (app.log)	Đội ngũ Giám sát / SOC	Trung bình	Integrity (I)	Lưu vết sự kiện, phục vụ điều tra sự cố an toàn thông tin

Bảng 6.1: Tài sản và dữ liệu cần bảo vệ

6.2. Mối đe dọa và lỗ hổng

ID	Tài sản	Mối đe dọa	Lỗ hổng	Tác động	Minh chứng/nguồn
T-01	Dữ liệu Telemetry	Giả mạo ID thiết bị (Device ID Spoofing)	Không kiểm tra Whitelist thiết bị đăng ký	Sai lệch dữ liệu hệ thống, đưa ra quyết định sai lầm	Thực nghiệm với fake-sensor-99 (HTTP Status 401)
T-02	Dữ liệu Telemetry	Mạo danh thiết bị bằng Token sai/thiếu	Cơ chế xác thực lỏng lẻo hoặc lộ khóa bí mật	Kẻ tấn công gửi dữ liệu rác dưới danh nghĩa thiết bị hợp lệ	Thực nghiệm với wrong_token_123 (HTTP Status 403)

ID	Tài sản	Mối đe dọa	Lỗ hổng	Tác động	Minh chứng/nguồn
T-03	Khóa xác thực (Token)	Bắt gói tin trên đường truyền (Eavesdropping/Sniffing)	Truyền tin qua HTTP thuần, chưa mã hóa SSL/TLS	Bị lộ Secret Token trên đường truyền mạng	Endpoint chạy trên http://127.0.0.1:5000
T-04	Dịch vụ API	Tấn công Từ chối dịch vụ (DoS / Brute-force)	Chưa cấu hình Rate Limiting cho API endpoint	Server bị quá tải, gián đoạn khả năng tiếp nhận dữ liệu	Flask Server chạy chế độ Development
T-05	Danh sách devices.json	Lộ/Sửa đổi trái phép tập tin cấu hình	Phân quyền truy cập tập tin (File Permission) chưa chặt chẽ	Lộ toàn bộ Token bí mật hoặc thêm trái phép ID giả mạo	Tập cấu hình lưu trữ dưới dạng Plaintext
T-06	Nhật ký (app.log)	Xóa dấu vết tấn công / Làm tràn bộ nhớ lưu trữ	Chưa có cơ chế phân quyền ghi Log và Log Rotation	Mất dữ liệu truy vết sự cố an toàn thông tin	Tập log lưu trữ trực tiếp trên đĩa cục bộ

Bảng 6.2: Mối đe dọa và lỗ hổng

6.3. Ma trận rủi ro

ID	Khả năng (1-5)	Tác động (1-5)	Điểm	Mức rủi ro	Biện pháp	Rủi ro còn lại
R-01	4	4	16	Cao	Kiểm tra danh sách trắng (devices.json) trước khi xử lý yêu cầu; phản hồi HTTP status 401 Unauthorized nếu ID không tồn tại.	Thấp
R-02	3	4	12	Trung bình	Yêu cầu xác thực khóa bí mật (token) đi kèm từng request; từ	Thấp

ID	Khả năng (1-5)	Tác động (1-5)	Điểm	Mức rủi ro	Biện pháp	Rủi ro còn lại
					chối và phản hồi HTTP status 403 Forbidden nếu sai khóa.	
R-03	4	4	16	Cao	Bắt buộc cấu hình giao thức HTTPS (TLS/SSL) để mã hóa toàn bộ dữ liệu telemetry và token trên đường truyền mạng.	Trung bình
R-04	3	3	9	Trung bình	Tích hợp thư viện Flask-Limiter để giới hạn số lượng request per minute (Rate Limiting) và triển khai trên môi trường WSGI production (như Gunicorn/Nginx).	Thấp
R-05	2	5	10	Trung bình	Phân quyền truy cập tệp tin trên hệ điều hành (chỉ cấp quyền Read cho tài khoản chạy Flask API); mã hóa tệp devices.json hoặc lưu trữ trên Database bảo mật.	Thấp
R-06	2	3	6	Thấp	Thiết lập cơ chế xoay vòng nhật ký (Log Rotation) định kỳ, phân quyền ghi log nâng cao và gửi log tập trung về hệ thống SIEM/SOC.	Thấp

Bảng 6.3: Ma trận rủi ro

6.4. Biện pháp giảm thiểu và ưu tiên

Dựa trên kết quả phân tích ma trận rủi ro, các biện pháp giảm thiểu được sắp xếp theo thứ tự ưu tiên xử lý như sau:

- Ưu tiên 1 - Triển khai mã hóa giao thức HTTPS / TLS (Xử lý rủi ro R-03):
 - Chủ thể thực hiện: Quản trị viên hệ thống / DevSecOps.
 - Độ khó / Chi phí: Độ khó Trung bình | Chi phí Thấp (Sử dụng chứng chỉ Let's Encrypt miễn phí).
 - Cách xác minh: Kiểm tra giao tiếp giữa thiết bị và Server qua Wireshark/tcpdump, đảm bảo các dữ liệu device_id và token đều được mã hóa SSL/TLS.

2. Ưu tiên 2 - Áp dụng cơ chế xác thực Whitelist & Token 2 lớp (Xử lý rủi ro R-01, R-02):
 - Chủ thể thực hiện: Lập trình viên Backend (Flask Developer).
 - Độ khó / Chi phí: Độ khó Thấp | Chi phí Rất thấp (Đã hoàn thành trong mã nguồn code_demo.py).
 - Cách xác minh: Gửi request test bằng curl với ID/Token giả mạo, kiểm tra hệ thống trả về HTTP 401 và 403 đúng kịch bản.
3. Ưu tiên 3 - Cấu hình Rate Limiting & Môi trường WSGI Production (Xử lý rủi ro R-04):
 - Chủ thể thực hiện: Quản trị hệ thống.
 - Độ khó / Chi phí: Độ khó Trung bình | Chi phí Thấp.
 - Cách xác minh: Sử dụng công cụ ab (ApacheBench) hoặc locust để gửi request dồn dập, xác nhận API tự động chặn khi vượt quá ngưỡng quy định.
4. Ưu tiên 4 - Quản lý an toàn tệp cấu hình và Nhật ký hệ thống (Xử lý rủi ro R-05, R-06):
 - Chủ thể thực hiện: Quản trị viên hệ thống.
 - Độ khó / Chi phí: Độ khó Thấp | Chi phí Thấp.
 - Cách xác minh: Phân quyền hệ điều hành chmod 600 cho devices.json và thiết lập logging.handlers.RotatingFileHandler cho tệp app.log.

6.5. Đánh giá an toàn sau xử lý

Rủi ro còn lại (Residual Risk): Sau khi áp dụng các biện pháp kiểm soát chính (Xác thực 2 lớp, Whitelist, Mã hóa TLS, Rate Limiting), rủi ro tổng thể của hệ thống giảm từ mức Cao xuống mức Thấp. Rủi ro còn lại chủ yếu nằm ở nguy cơ lộ Secret Token từ chính thiết bị phần cứng nếu thiết bị bị chiếm quyền điều khiển vật lý (Physical Attack).

Điều kiện chấp nhận rủi ro: Chấp nhận rủi ro vật lý trên thiết bị đầu cuối đối với các node cảm biến giá rẻ, không chứa dữ liệu quá nhạy cảm.

Kiểm soát cần theo dõi định kỳ:

- Giám sát thường xuyên các cảnh báo [SPOOF DETECTED] trong tệp app.log để phát hiện sớm các đợt dò quét / tấn công dò đoán Token.
- Tự động xoay vòng (Rotate) Secret Token định kỳ mỗi 30-90 ngày.

CHƯƠNG 7. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

7.1. Kết luận

Tóm tắt vấn đề: Giả mạo thiết bị (Device Spoofing) là một trong những nguy cơ an toàn thông tin nghiêm trọng nhất đối với hệ thống IoT, cho phép kẻ tấn công chèn dữ liệu sai lệch, gây nhiễu loạn vận hành và làm mất tính toàn vẹn (Integrity) của hệ thống.

Phương pháp thực hiện: Đề tài đã xây dựng thành công một mô hình Server REST API bằng Python/Flask (code_demo.py), tích hợp cơ chế xác thực hai lớp bao gồm: Kiểm tra danh sách trắng thiết bị hợp lệ (devices.json) và Xác thực khóa bí mật (token).

Kết quả nổi bật:

- Tiếp nhận và xử lý mượt mà dữ liệu telemetry từ thiết bị chính thống (sensor-node-01) với phản hồi HTTP 200 OK.
- Ngăn chặn chính xác 100% các kịch bản tấn công thử nghiệm: Chặn thiết bị không đăng ký (fake-sensor-99) với lỗi HTTP 401 Unauthorized và chặn thiết bị dùng sai khóa xác thực với lỗi HTTP 403 Forbidden.
- Tự động ghi nhận đầy đủ, chuẩn hóa nhật ký sự kiện và cảnh báo tấn công vào tệp app.log.

Mức độ hoàn thành: Đề tài đã hoàn thành 100% các mục tiêu đề ra, đáp ứng đầy đủ cả về mặt lý thuyết lẫn thực nghiệm mô phỏng.

7.2. Hướng phát triển

1. Thực nghiệm trên phần cứng IoT thực tế: Triển khai mã nguồn client lên các bo mạch vi điều khiển thực tế như ESP32, ESP8266 hoặc Raspberry Pi truyền dữ liệu qua mạng Wi-Fi/4G thay vì giả lập bằng lệnh curl.
2. Nâng cấp giao thức truyền tải an toàn: Chuyển đổi từ HTTP sang giao thức HTTPS (TLS/SSL) hoặc áp dụng giao thức MQTT với TLS (MQTTs) chuyên dụng cho IoT để chống bắt gói tin.
3. Áp dụng cơ chế xác thực nâng cao: Thay thế Token tĩnh bằng Token động có thời hạn (JWT - JSON Web Token) hoặc cơ chế xác thực hai chiều dựa trên chứng chỉ số (mTLS - Mutual TLS).
4. Tích hợp Trí tuệ nhân tạo (AI/ML) phát hiện bất thường: Phát triển thêm mô hình Machine Learning phân tích hành vi gửi dữ liệu (tần suất, dải giá trị cảm biến, vị trí IP) để phát hiện các cuộc tấn công giả mạo tinh vi ngay cả khi kẻ tấn công đánh cắp được Token hợp lệ.

TÀI LIỆU THAM KHẢO

- [1] OWASP Foundation, OWASP IoT Security Verification Standard (ISVS). [Online]. Available: <https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS>. [Accessed: Jul. 22, 2026].
- [2] OWASP Foundation, OWASP Internet of Things Security Verification Standard. [Online]. Available: <https://owasp.org/www-project-iot-security-verification-standard/>. [Accessed: Jul. 22, 2026].
- [3] Pallets Project, Flask. GitHub Repository. [Online]. Available: <https://github.com/pallets/flask>. [Accessed: Jul. 22, 2026].
- [4] Pallets Project, Flask Documentation. [Online]. Available: <https://flask.palletsprojects.com/>. [Accessed: Jul. 22, 2026].
- [5] Mbed TLS Team, Mbed TLS. GitHub Repository. [Online]. Available: <https://github.com/Mbed-TLS/mbedtls>. [Accessed: Jul. 22, 2026].
- [6] Mbed TLS Team, Mbed TLS Documentation. [Online]. Available: <https://mbed-tls.readthedocs.io/>. [Accessed: Jul. 22, 2026].
- [7] OWASP Foundation, OWASP Cheat Sheet Series. [Online]. Available: <https://cheatsheetseries.owasp.org/>. [Accessed: Jul. 22, 2026].
- [8] OWASP Foundation, Transport Layer Security Cheat Sheet. [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html. [Accessed: Jul. 22, 2026].
- [9] OWASP Foundation, Logging Cheat Sheet. [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html. [Accessed: Jul. 22, 2026].

PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP

ĐỀ TÀI 28 - GIẢ MẠO THIẾT BỊ TRONG HỆ THỐNG IOT

— README.md	# Hướng dẫn chạy và kiểm thử dự án
— report/	# Báo cáo tiểu luận (.docx / .pdf)
— slides/	# Slide thuyết trình (.pptx)
— src/	# Mã nguồn chương trình
— code_demo.py	# Flask API kiểm tra và xác thực thiết bị
— configs/	# Cấu hình hệ thống
— config.json	# Tham số cấu hình server & bảo mật
— data/	# Dữ liệu quản lý
— devices.json	# Danh sách thiết bị hợp lệ (Whitelist)
— results/	# Kết quả kiểm thử
— screenshots/	# Ảnh chụp màn hình quá trình test
— logs/	# Nhật ký ghi nhận các truy cập (app.log)
— references/	# Tài liệu tham khảo
— link_nguồn.md	# Nguồn OWASP ISVS, Flask, Mbed TLS

PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP

STT	Nội dung kiểm tra	Trạng thái
1	Báo cáo đủ 7 phần chính, mục lục và tài liệu tham khảo.	✓ Đạt ☐ Chưa đạt
2	Độ dài báo cáo chính 10-15 trang, không tính phụ lục.	✓ Đạt ☐ Chưa đạt
3	Repo mở được; README có cách chạy/sử dụng và mô tả cấu trúc.	✓ Đạt ☐ Chưa đạt
4	Có sản phẩm kỹ thuật hoặc sản phẩm phân tích hoàn chỉnh.	✓ Đạt ☐ Chưa đạt
5	Có ít nhất 3 minh chứng kiểm tra được trong results/ hoặc báo cáo.	✓ Đạt ☐ Chưa đạt
6	Có ít nhất 5 tài liệu tham khảo và repo GitHub/tool chính.	✓ Đạt ☐ Chưa đạt
7	Mọi hình/bảng có tên, số thứ tự, nguồn và phần phân tích.	✓ Đạt ☐ Chưa đạt
8	Không có secret, token, mật khẩu, dữ liệu cá nhân hoặc file nhạy cảm.	✓ Đạt ☐ Chưa đạt
9	Mọi thử nghiệm chỉ diễn ra trong môi trường local/được phép.	✓ Đạt ☐ Chưa đạt
10	Slide có 8-12 trang, link repo, kết quả chính, rủi ro và kết luận.	✓ Đạt ☐ Chưa đạt
11	Đã cập nhật mục lục, kiểm tra chính tả và xóa toàn bộ hướng dẫn mẫu.	✓ Đạt ☐ Chưa đạt

PHỤ LỤC D. PHIẾU TỰ ĐÁNH GIÁ THEO RUBRIC

Tiêu chí	Điểm tối đa	Tự chấm	Minh chứng/ghi chú
Đúng đề tài, đúng phạm vi	1,0	1,0	Đã hoàn thành
Nguồn GitHub và tài liệu tham khảo	1,0	1,0	Đã hoàn thành
Cơ sở lý thuyết	1,0	1,0	Đã hoàn thành
Cách làm/phương pháp	1,0	1,0	Đã hoàn thành
Sản phẩm kỹ thuật hoặc sản phẩm phân tích	2,0	2,0	Đã hoàn thành
Phân tích bảo mật/rủi ro/biện pháp	1,5	1,5	Đã hoàn thành
Trình bày, hình bảng và trích dẫn	1,0	1,0	Đã hoàn thành
Slide và bảo vệ	1,0	1,0	Đã hoàn thành
Tuân thủ an toàn và đạo đức	0,5	0,5	Đã hoàn thành
TỔNG	10,0	10,0	Đã hoàn thành